

Industrial Security (Bachelor)

Solution Sheet – Section 08

Defense in Depth

Exercise 8.1 – Layered Controls (sample)

Control	Layer	Type
Contractor escort policy	Policy	Preventive
Locked USB ports / physical port covers	Physical	Preventive
Disable USB mass storage at OS	Host	Preventive
USB allow-list (whitelisted devices)	Host	Preventive
AppLocker / WDAC on the WS	Host	Preventive
EDR alert on suspicious child process	Host	Detective
Network monitoring of WS outbound traffic	Network	Detective
Segmentation between WS and PLCs (DPI)	Network	Preventive
RBAC + MFA for engineering tool	Identity	Preventive
Logging + SOC review	Monitoring	Detective
IR playbook, rapid re-image policy	Process	Corrective

Exercise 8.2 – AppLocker Lab Notes

Expected log: Event ID 8004 (Exe blocked) and 8007 (Script blocked) under *Applications and Services Logs* → *Microsoft* → *Windows* → *AppLocker*. User receives a Windows toast or explicit denial dialogue.

Exercise 8.3 – IDS Lab Notes

Malcolm dashboards will show: a previously unseen Modbus client IP, write function codes from an unexpected source, and elevated alert count after the injection. Tuning a false positive typically involves whitelisting a known scheduled task or polling interval.

Exercise 8.4 – Remote Access (sample)

Components: vendor laptop → brokered portal (MFA) → iDMZ jump host (session recording) → industrial firewall → PLC. Operator approval gates each session.

Failure modes:

- Vendor MFA token compromised → jump host still enforces operator approval and session recording.
- Operator unavailable → design must include a back-up approver and a clear escalation; never grant “standing” access.